

Endpoint and Clinical Device Security Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-010

Version 1.0 | Effective: 18 Feb 2026

Field	Details
Policy Title	Endpoint and Clinical Device Security Policy
Policy Number	FTAID-POL-010
Author	Oluwatobi Emmanuel Owoye
Policy Owner	Chief Information Security Officer (CISO)
Reviewer	Information Security Manager
Approver	Chief Executive Officer (CEO), FortisAid
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO/IEC 27002:2022 Domain	Technological Controls
ISO/IEC 27002:2022 Sub-domain(s)	8.1 User Endpoint Devices 8.7 Protection Against Malware 8.10 Information Deletion
ISO/IEC 27002:2022 Control Reference(s)	8.1, 8.7, 8.10
Related Policies	Identity Management and Access Control Policy Incident Management Policy Information Classification Policy
Approval Status	Approved

Approval Evidence

Approver: Chief Executive Officer (CEO)

Title: CEO, FortisAid

Signature:  _____

Date: 18 February 2026

Purpose:

This policy establishes security requirements for endpoint and clinical devices at FortisAid to ensure the confidentiality, integrity, and availability of patient and organizational information.

It ensures compliance with healthcare regulatory obligations, industry best practices, and ISO/IEC 27002:2022 control requirements.

Scope:

This policy applies to:

- All endpoint devices, clinical systems, servers, storage media, and cloud-hosted workloads, within FortisAid.
- All employees, contractors, and third-party users with access to these systems used

FortisAid Context:

As a healthcare organization handling sensitive clinical data, FortisAid relies on secure endpoints and medical technologies, including Electronic Health Record (EHR) systems, cloud-integrated diagnostic devices, and remote monitoring tools. This policy ensures these systems are protected against malware, ransomware, unauthorized access, and operational disruptions that could impact patient care

ISO 27002:2022 Alignment

ISO Domain	ISO Sub-domain	Control Number	How this policy addresses it
Technological Controls	User Endpoint Devices	8.1	Ensures endpoint devices are securely configured, hardened, and monitored.
Technological Controls	Protection Against Malware	8.7	Requires anti-malware and endpoint detection and response (EDR) solutions.
Technological Controls	Information Deletion	8.10	Ensures secure deletion of sensitive data before device disposal or reassignment.

Threats & Key Risks

Major Threats:

Ransomware attacks, unpatched clinical systems, unauthorized access to devices containing Protected Health Information (PHI), and compromise of IoT-enabled medical equipment.

Key Risks:

- Exposure of PHI leading to regulatory penalties and reputational damage.
- Disruption of clinical services due to malware or compromised devices.
- Unauthorized modification of diagnostic devices affecting patient safety.

Policy Statements

User Endpoint Devices

- All endpoint devices must be configured according to approved secure baseline standards before deployment.
- Only authorized and managed devices may connect to FortisAid's network or cloud resources.
- Administrative privileges on endpoints must be restricted and granted based on least privilege principles.
- Endpoint devices must have disk encryption enabled to protect data at rest.
- Automatic screen lock must activate after a defined period of inactivity.
- Lost or stolen devices must be reported immediately and remotely disabled or wiped where possible.

Protection Against Malware

- Approved anti-malware and Endpoint Detection & Response (EDR) solutions must be installed and active on all systems.
- Malware signatures and detection engines must update automatically.
- Real-time protection must not be disabled without formal authorization.
- Email attachments, removable media, and downloaded files must be automatically scanned.
- Security alerts generated by anti-malware systems must be investigated promptly.
- Users must not install unauthorized software.

Information Deletion

- Sensitive data must be securely deleted using approved data sanitization methods prior to device reuse or disposal.
- Storage media must be wiped in accordance with recognized data destruction standards.
- Devices that cannot be securely sanitized must be physically destroyed.
- Data deletion activities must be documented and approved.
- Disposal vendors must provide certification of destruction where applicable.

Roles and Responsibilities

- **Chief Information Security Officer (CISO)** – Overall accountability for endpoint and clinical device security.
- **IT Security Team** – Implement secure configurations, monitor malware protection, and oversee secure deletion procedures.
- **Information Security Manager** – Validate compliance, review audit reports, and approve data deletion activities.
- **IT Operations / Asset Management Team** – Execute secure deletion, maintain device inventory, and document disposal activities.
- **Users / Staff** – Ensure proper use of endpoint devices, report lost/stolen devices, and follow security guidelines.

Compliance & Monitoring

- All endpoints and clinical devices will be continuously monitored for security compliance.
- Security alerts, malware detections, and data deletion logs will be reviewed regularly by the Security Operations team.
- Non-compliant systems may be isolated or restricted until remediation is complete.

Training & Review Cycle

- Mandatory security training for all staff (with specialized training for technical roles).
- This policy will be reviewed **annually**, after major incidents or following significant changes in technology, regulatory requirements, or threat landscape.
- Next review: 18 February 2027.